
Tag Traditions

HERITAGE & GI-TAGGED MARKETPLACE

Technology Stack & Integration Specification

A complete technical reference for the Tag Traditions platform — the technology stack, every software package and tool, every third-party service the platform depends on, how each of those services is onboarded, and what is required from the Company to enable them.

DOCUMENT

Technology & Integration Specification

PREPARED FOR

The Company

STATUS

For review

PLATFORM

Tag Traditions Marketplace

PREPARED BY

The Development Team

COMPANION TO

Scope of Work §1.1–§1.4

CONTENTS

Table of Contents

1 About This Document

2 Platform Overview

3 Technology Stack

- 3.1 Stack at a Glance
- 3.2 Frontend Layer — React
- 3.3 Application Layer — Node.js & Express
- 3.4 Data Layer — MongoDB Atlas
- 3.5 Cache, Queue & Real-Time Layer
- 3.6 Search Layer
- 3.7 Media & Storage Layer
- 3.8 Mobile Applications
- 3.9 Infrastructure & Hosting

4 Package Inventory

- 4.1 Backend Runtime Packages
- 4.2 Backend Development Packages
- 4.3 Frontend Packages
- 4.4 Shared Contract Package
- 4.5 Mobile Application Packages

5 Development & Delivery Tooling

6 Third-Party Integrations

- 6.1 Payments
- 6.2 Logistics & Shipping
- 6.3 Quick-Commerce Channels
- 6.4 Communications
- 6.5 Identity & Sign-In
- 6.6 Cloud, Storage & Delivery
- 6.7 Taxation & Invoicing
- 6.8 Seller Verification & KYC
- 6.9 Maps & Address
- 6.10 Analytics
- 6.11 Security & Anti-Abuse
- 6.12 Monitoring & Error Tracking
- 6.13 App Store Distribution

7 Integration Onboarding Process

8	Requirements From the Company
9	Decisions Required Before Build
10	How We Will Proceed
11	Environments & Configuration
12	Security, Compliance & Data Residency
13	Assumptions & Dependencies
A	Appendix A — Configuration Reference
B	Appendix B — Glossary

SECTION 1

About This Document

This document is the single technical reference for the Tag Traditions platform. It answers, in one place, what the platform is built with, what it depends on, and what is needed to switch each of those dependencies on.

1.1 Purpose

The Scope of Work describes *what* the platform must do. This document describes *what it will be built from* and *what must be procured, provisioned and decided* for that build to proceed without interruption. It exists so that no external dependency — an account, a key, a certificate, a business rule — is discovered late.

1.2 What this document covers

- **The complete technology stack**, layer by layer, with the reason each technology was selected.
- **Every software package** that will be installed in the codebase, what it does, and which layer it belongs to.
- **Every development, testing and operations tool** used to build, verify and run the platform.
- **Every third-party integration** — the service, what it powers, the credentials it needs, and who is responsible for obtaining them.
- **The onboarding path for each integration**, from account creation through sandbox testing to production activation.
- **A consolidated list of everything required from the Company**, presented as an actionable checklist.
- **The decisions that must be settled before build begins**, drawn from gaps in the Scope of Work.
- **The stage-by-stage delivery approach** and the engineering practices applied throughout.

1.3 What this document deliberately excludes

By instruction, this document contains **no timelines, no schedules, no effort estimates, no commercial terms and no pricing**. Those are governed by the commercial agreement and are addressed separately. Sequencing is described only in terms of logical dependency — which work must precede which — never in terms of duration.

1.4 Intended audience

READER	HOW TO USE THIS DOCUMENT
Company leadership	Sections 1, 2, 8, 9 and 10 — what is being built, what is needed from the Company, what must be decided, and how the work will proceed.
Company operations & finance	Sections 6, 7 and 8 — the third-party accounts to be opened, the KYC each requires, and the credentials to be handed over.

READER	HOW TO USE THIS DOCUMENT
Company legal & compliance	Sections 6.7, 6.8 and 12 — taxation, verification, data residency and the statutory obligations the platform must satisfy.
Technical reviewers	Sections 3, 4, 5 and 11 — the stack, the package inventory, the tooling and the configuration surface.

1.5 Terminology

Throughout this document, **the Company** means Tag Traditions as the platform owner, and **the Development Team** means the party responsible for delivery. **Seller** and **Vendor** are used interchangeably. A full glossary appears in Appendix B.

A NOTE ON RESPONSIBILITY

Third-party services fall into two categories. **Company-owned** services require a legal entity, KYC documents, a bank account or a commercial agreement — only the Company can open these. **Team-owned** services are technical infrastructure the Development Team provisions and configures. Section 6 marks every integration with its owner, and Section 8 consolidates all Company-owned items into a single checklist.

SECTION 2

Platform Overview

Tag Traditions is a multi-vendor marketplace for authentic Indian heritage goods. Its distinguishing characteristic is that authenticity is verified, not claimed — and that requirement shapes the technical decisions in every section that follows.

2.1 What the platform sells

The catalogue is organised into three distinct product classes, each with different verification and content requirements:

PRODUCT CLASS	DEFINITION	VERIFICATION REQUIREMENT
GI-Tagged products	Goods carrying a registered Geographical Indication — a legal mark tying the product to a place of origin whose qualities derive from that place. Examples include Darjeeling Tea, Kanchipuram Silk, Pashmina and Alphonso Mango.	Registered GI certificate, verified against certificate documentation, with badge display.
Heritage products (non-GI)	Traditional craft goods of cultural provenance that do not hold a GI registration.	Seller and craft provenance disclosure; no GI badge.
Tradition-based items	Goods tied to rituals, festivals, scriptures and observances.	Content accuracy review against tradition references.

2.2 Why authenticity drives the architecture

Anyone can describe a product as “Darjeeling tea”. Only a registered proprietor or authorised user may lawfully do so. The platform's commercial value rests on the guarantee that a badge on a listing corresponds to a certificate that a named officer has examined. This has three architectural consequences that recur throughout this document:

- **A verification workflow sits between a seller and the storefront.** Listings do not go live on submission; they enter a review queue. This requires state machines, reviewer tooling, structured rejection reasons, and an audit trail.
- **Certificates expire.** Verification is not a one-time event but a recurring obligation, requiring scheduled background processing and seller notification — which is why a job queue is a core component rather than an optional one.
- **Every verification decision must be attributable.** Who approved what, when, and on what basis must be reconstructable — which makes immutable audit logging a first-class requirement, not an afterthought.

2.3 Who uses the platform

ROLE	DESCRIPTION	PRIMARY SURFACE
Guest	An unauthenticated visitor. Has full read access to the catalogue and all heritage content, and may complete a purchase — guest checkout is an explicit requirement. This is the widest public surface and carries the search-engine and first-visit load.	Public storefront
Customer	A registered buyer. Everything a guest can do, plus identity: profile, saved addresses, wishlist, order history, returns and exchanges, reviews, referrals and notification preferences.	Storefront + account area
Vendor / Seller	An artisan, cooperative or merchant listing on the platform. Manages listings, inventory, orders against their products, and views payouts. Subject to onboarding, KYC and verification before selling.	Seller portal
Admin	Company staff, operating under role-based access control with configurable permission levels, across users, products, orders, sellers, content, payments and analytics.	Admin panel

2.4 Delivery surfaces

SURFACE	AUDIENCE	TECHNICAL CHARACTERISTICS
Public storefront	Guest, Customer	Search-engine indexable, high traffic, performance-critical, bilingual, accessible to WCAG 2.1 AA.
Seller portal	Vendor	Authenticated application. Data-entry and dashboard heavy. No search-engine requirement.
Admin panel	Admin	Authenticated application under RBAC. Tabular, workflow and reporting heavy. No search-engine requirement.
Mobile applications	Customer	iOS and Android. Consume the same API as the web. Receive push notifications.

ARCHITECTURAL IMPLICATION

The storefront and the two back-office panels have opposite technical priorities. The storefront must be indexable by search engines and fast on first visit; the panels must be rich, stateful and responsive after login but are never indexed. Section 3.2 explains how the frontend architecture serves both without compromise.

2.5 How the platform operates commercially

Tag Traditions is a marketplace, not a retailer: the platform does not own inventory. Sellers list goods, buyers purchase them, the platform facilitates payment and fulfilment, and settles to sellers net of platform charges and applicable deductions. The technical consequences are that the system must maintain a ledger of seller earnings distinct from gross order value, hold funds through the returns window before releasing them,

calculate deductions correctly, and produce compliant tax documentation on both sides of every transaction. These flows are described in Sections 6.1, 6.7 and 9.

SECTION 3

Technology Stack

The platform is built on the MERN stack — MongoDB, Express.js, React and Node.js — with a single language, TypeScript, across the entire codebase. This section documents every layer, the technology chosen for it, and the reasoning behind that choice.

3.1 Stack at a glance

LAYER	TECHNOLOGY	ROLE IN THE PLATFORM
CORE STACK		
Language	TypeScript 5.x	Single language across server, web and mobile. Type contracts are shared, so an API change that breaks a client fails at compile time rather than in production.
Runtime	Node.js 22 LTS	Server runtime. Long-term-support release for the security-patch window.
API framework	Express.js 5.x	HTTP server, routing and middleware pipeline for the REST API.
Database	MongoDB Atlas 7.x	Primary data store, managed, hosted in the Mumbai region for data residency.
Data modelling	Mongoose 8.x	Schema definition, validation, population and transaction sessions over MongoDB.
Web frontend	React 19	All four user surfaces.
SUPPORTING SERVICES		
Cache & sessions	Redis 7	Response caching, rate-limit counters, session and token state, idempotency keys.
Background jobs	BullMQ	Asynchronous work: notifications, invoices, search indexing, certificate expiry sweeps, payout runs.
Real-time	Socket.IO 4.x	Live order status, in-app notifications, seller-buyer messaging.
Search	MongoDB Atlas Search	Full-text catalogue search, faceted filtering, autocomplete. Native to Atlas, removing a separate search cluster.
Object storage	AWS S3 (Mumbai)	Product imagery, seller documents, GI certificates, invoices, exports.
Content delivery	AWS CloudFront	Global media delivery with signed URLs for private assets.

LAYER	TECHNOLOGY	ROLE IN THE PLATFORM
CLIENT APPLICATIONS		
Storefront rendering	Vite + React with SSR	Server-rendered public pages for search-engine indexing and first-visit performance.
Panel rendering	Vite + React SPA	Single-page applications for seller and admin panels.
Mobile	React Native (Expo)	iOS and Android from one codebase, sharing types and API client with the web.
OPERATIONS		
Containerisation	Docker	Identical environments from a developer machine through to production.
Error tracking	Sentry	Server and client exception capture with release tracking.
Logging	Pino	Structured JSON logs with request correlation identifiers.

3.2 Frontend layer — React

All four surfaces are built in React 19 with TypeScript, sharing one component library, one design system and one API client. They differ in how they are rendered, because their requirements differ.

Rendering strategy

SURFACE	RENDERING	REASON
Storefront — catalogue, product pages, heritage content, blog, events	Server-side rendered React	These pages must be indexed by search engines and must render meaningful content on first paint. A client-only application returns an empty shell to a crawler, which would remove the catalogue and all heritage content from search results.
Seller portal	Single-page application	Sits behind authentication and is never indexed. A single-page application gives faster in-session navigation and simpler state handling.
Admin panel	Single-page application	As above. Heavy tabular and dashboard interaction benefits from persistent client state.

WHY THIS MATTERS COMMERCIALY

The storefront's traffic model depends on organic discovery of product, category, region, artisan and heritage-story pages. Server-side rendering for the public surface is therefore a commercial requirement expressed as a technical one, not a developer preference. The two back-office panels carry no such requirement and are built as single-page applications, which is the simpler and faster approach where it is appropriate.

Frontend composition

- **Build tooling** — Vite, for fast development rebuilds and optimised production bundles with code splitting per route.
- **Routing** — React Router, with route-level code splitting so a visitor loads only the code for the page they are on.
- **Server state** — TanStack Query, managing all API data: caching, background refresh, request deduplication and optimistic updates.
- **Client state** — Zustand, for genuinely local state such as cart preview, UI preferences, theme and recently-viewed items.
- **Styling** — Tailwind CSS with a design-token layer, so brand colours, spacing and typography are defined once and applied consistently.
- **Components** — shadcn/ui built on Radix primitives, which provide keyboard navigation, focus management and screen-reader semantics required for WCAG 2.1 AA.
- **Forms** — React Hook Form with Zod validation, using the same schemas the server validates against.
- **Internationalisation** — i18next, with all interface text externalised into translation files for English and Hindi.

3.3 Application layer — Node.js and Express

The API is a single Express application exposing versioned REST endpoints, a WebSocket gateway and webhook receivers. Although the framework is minimal by design, the application is structured in disciplined layers rather than as loose route handlers.

Request pipeline

Every request passes through an ordered middleware chain before reaching business logic:

#	STAGE	FUNCTION
1	Security headers	Helmet applies content-security, frame, transport and referrer policies.
2	Cross-origin policy	CORS restricted to known application origins.
3	Request correlation	A unique identifier is attached to the request and carried through every log line and downstream call.
4	Body parsing	JSON and form parsing, with the raw body preserved for webhook signature verification.
5	Rate limiting	Redis-backed counters per client and per route class.
6	Authentication	Access token verification; the authenticated principal is attached to the request.
7	Authorisation	Role and permission checks against the RBAC model.
8	Validation	Zod schemas validate body, query and parameters; unknown fields are rejected.
9	Idempotency	For state-changing operations, a repeated key returns the original result rather than repeating the action.

#	STAGE	FUNCTION
10	Handler	Controller delegates to a service; the service holds the business logic.
11	Response shaping	All responses are wrapped in one consistent envelope.
12	Error handling	A single error handler converts every failure into a consistent, documented error response.

Internal module structure

Business capability is organised into modules, each following the same internal shape — routes, controllers, services, models, validators. The modules are: authentication, users, sellers, catalogue, categories, GI verification, cart, wishlist, orders, payments, shipping, returns, reviews, promotions, referrals, loyalty, notifications, messaging, support, content, events, finance and settlement, reporting, administration, and webhooks.

Process types

The same codebase runs in three distinct process roles, selected by configuration, so each can be scaled independently:

- **API process** — serves HTTP and WebSocket traffic.
- **Worker process** — consumes background job queues.
- **Scheduler process** — triggers recurring work such as certificate expiry sweeps, settlement runs and report generation, using a distributed lock so exactly one instance acts.

3.4 Data layer — MongoDB Atlas

MongoDB Atlas is the managed database service. It is provisioned in the **Mumbai (ap-south-1) region** to satisfy the India-only data residency obligation described in Section 12.

Why Atlas rather than self-managed MongoDB

- Automated backups with point-in-time recovery, which is a compliance requirement rather than a convenience.
- Replica-set topology by default, which is a precondition for the multi-document transactions the order and settlement flows require.
- Encryption at rest and in transit managed by the platform, satisfying the AES-256 and TLS obligations.
- Atlas Search included, removing the need to operate a separate search cluster.
- Region pinning, which makes the data-residency position demonstrable to an auditor.

Data modelling approach

Document databases reward deliberate modelling. Three rules are applied consistently across the schema:

RULE	APPLICATION
Embed what is bounded and always read together	Product images, product variants, order line items, order status history, addresses within a customer record, and message entries within a conversation.
Reference what is shared, independently queried, or unbounded	Users, products, orders, seller profiles, categories, coupons and payment records.
Snapshot at the moment of writing	An order line stores the product name, price, tax treatment, seller identity and GI status as <i>they were at the time of purchase</i> . It does not read them live. An order from last year must render exactly as it was placed, regardless of subsequent catalogue changes.

MONETARY VALUES

All monetary amounts are stored as `Decimal128`, never as ordinary floating-point numbers. Floating-point arithmetic introduces small errors that accumulate across commission calculations, tax computation and settlement, producing figures that do not reconcile. This applies uniformly to prices, taxes, discounts, commissions, refunds and payouts.

Transactional integrity

Certain operations must either complete in full or not at all — placing an order while reserving stock and recording payment; processing a return while restoring stock, issuing a refund and adjusting seller earnings; executing a settlement run. These use MongoDB multi-document transactions with an explicit session, supported by the Atlas replica-set topology.

3.5 Cache, queue and real-time layer

COMPONENT	TECHNOLOGY	FUNCTION
Cache	Redis 7	Caches catalogue responses, category trees, configuration and computed aggregates. Reduces database load on the highest-traffic public endpoints.
Session & token store	Redis 7	Refresh-token state and revocation lists, so a sign-out or a compromised token takes effect immediately across all processes.
Rate limiting	Redis 7	Shared counters, so limits hold across every running instance rather than per-instance.
Idempotency	Redis 7	Short-lived keys ensuring a retried payment or order request does not execute twice.
Job queue	BullMQ on Redis	Durable background processing with retries, exponential back-off, delayed execution, recurring schedules and dead-letter handling.

COMPONENT	TECHNOLOGY	FUNCTION
Real-time transport	Socket.IO with Redis adapter	WebSocket connections for live updates, with the adapter broadcasting across all server instances.

Work handled asynchronously

Anything slow, failure-prone or dependent on an external service is queued rather than performed inside a request, so that a third-party outage degrades a feature instead of failing a customer transaction:

- Transactional email dispatch
- SMS and OTP dispatch
- Push notification delivery
- Search index synchronisation
- Invoice generation and storage
- Image processing and variant generation
- GI certificate expiry sweeps
- Settlement and payout runs
- Report generation and export
- Outbound webhook delivery with retry
- Shipment tracking reconciliation
- Abandoned-cart and re-engagement flows

3.6 Search layer

MongoDB Atlas Search provides catalogue search, built on Apache Lucene and running inside the Atlas cluster. It supports full-text relevance, fuzzy matching for misspellings, faceted filtering, autocomplete and synonym mapping — the last being genuinely useful here, where a single item may be sought by several regional names.

Search covers the filter dimensions the Scope of Work requires: GI certification status, state or region of origin, category, price range, artisan, tradition and product type. Index updates are applied asynchronously whenever a listing is created, approved, edited, restocked or withdrawn.

Choosing Atlas Search over a separate Elasticsearch or OpenSearch cluster removes an entire piece of infrastructure — with its own hosting, scaling, security and synchronisation burden — from the platform. Should catalogue scale or relevance requirements later exceed what Atlas Search provides, the search layer is isolated behind an internal interface and can be replaced without altering application code.

3.7 Media and storage layer

COMPONENT	FUNCTION
AWS S3 (Mumbai)	Object storage, separated into a public bucket for catalogue and editorial media and a private bucket for seller documents, GI certificates, invoices and data exports.
AWS CloudFront	Content delivery for public media. Private objects are served only through time-limited signed URLs.
Sharp	Server-side image processing: responsive size variants, WebP and AVIF conversion, compression and metadata stripping, performed asynchronously on upload.
PDFKit	Server-side generation of GST-compliant invoices, credit notes, shipping manifests and settlement statements.

COMPONENT	FUNCTION
ExcelJS	Generation of Excel and CSV exports for the reporting requirements in the Scope of Work.

DOCUMENT SENSITIVITY

Seller KYC documents and GI certificates contain personal and commercially sensitive information. They are never placed in the public bucket and are never served through a permanent URL. Access is granted only through short-lived signed links issued to an authenticated, authorised user, and every access is recorded in the audit log.

3.8 Mobile applications

The iOS and Android applications are built with **React Native via Expo**, from a single codebase that shares its TypeScript types, validation schemas and API client with the web application. The applications consume exactly the same API — no mobile-specific backend is built or maintained.

- **Push notifications** — Firebase Cloud Messaging on Android and Apple Push Notification service on iOS, both reached through the Expo notification layer.
- **Payments** — the Razorpay React Native SDK, providing native UPI intent handling.
- **Deep linking** — universal and app links, so referral codes and shared product links open directly in the application when installed.
- **Distribution** — Expo Application Services for building and submitting to both stores, with over-the-air updates for JavaScript-only changes.

3.9 Infrastructure and hosting

All infrastructure is provisioned in an **India region**, without exception, for the reasons set out in Section 12.

COMPONENT	SERVICE	NOTES
Application hosting	AWS ECS on Fargate, Mumbai	Containerised API, worker and scheduler processes, scaled independently.
Database	MongoDB Atlas, Mumbai	Managed replica set with automated backup and point-in-time recovery.
Cache and queue	AWS ElastiCache for Redis, Mumbai	Managed Redis with encryption in transit and at rest.
Object storage	AWS S3, Mumbai	Versioned, encrypted, lifecycle-managed.
Content delivery	AWS CloudFront	Edge caching for public media and static assets.
Load balancing	AWS Application Load Balancer	TLS 1.3 termination and health-checked routing.
Edge protection	Cloudflare	DNS, web application firewall, bot management and denial-of-service protection.

COMPONENT	SERVICE	NOTES
Secrets	AWS Secrets Manager	All credentials, loaded at process start. No secret is present in source control.
Certificates	AWS Certificate Manager	TLS certificates with automatic renewal.

SECTION 4

Package Inventory

This section lists every software package installed in the codebase, grouped by the layer it serves, with its purpose stated. Version notation follows the major-version line that will be used; exact patch versions are pinned in the project's lock files and updated under the maintenance practice described in Section 10.

HOW TO READ THESE TABLES

Packages are open-source libraries installed into the codebase. They carry no licence cost. They are listed here for completeness and for technical review, so that the Company has a full account of what the platform is assembled from. Third-party *services* — which do require accounts, and in some cases fees — are covered separately in Section 6.

4.1 Backend runtime packages

Installed on the server and running in production.

PACKAGE	VERSION	PURPOSE
CORE SERVER		
express	5.x	HTTP server framework — routing, middleware pipeline, request and response handling.
mongoose	8.x	MongoDB object modelling: schema definition, validation, population, transaction sessions, middleware hooks.
mongodb	6.x	Official MongoDB driver, used directly for aggregation pipelines and bulk operations.
typescript	5.x	Type system and compiler for the entire server codebase.
tsx	4.x	TypeScript execution for development with automatic reload.
dotenv	16.x	Loads environment configuration in non-production environments.
SECURITY AND AUTHENTICATION		
jsonwebtoken	9.x	Issues and verifies access and refresh tokens.
bcrypt	5.x	Password hashing with per-password salt and configurable work factor.
helmet	8.x	Sets security-related HTTP response headers.
cors	2.x	Cross-origin resource sharing policy enforcement.

PACKAGE	VERSION	PURPOSE
express-rate-limit	7.x	Request rate limiting, backed by the Redis store below.
rate-limit-redis	4.x	Shared rate-limit counters across all server instances.
express-mongo-sanitize	2.x	Strips operator injection attempts from request payloads.
cookie-parser	1.4.x	Parses cookies; refresh tokens are held in HTTP-only cookies.
passport	0.7.x	Authentication strategy framework for social sign-in.
passport-google-oauth20	2.x	Google single sign-on.
passport-facebook	3.x	Facebook single sign-on.
speakeasy	2.x	Time-based one-time passwords for administrator two-factor authentication.
VALIDATION AND CONTRACTS		
zod	3.x	Schema validation for every request. The same schemas are shared with the frontend, so client and server validate identically.
@asteasolutions/zod-to-openapi	7.x	Generates the OpenAPI specification directly from the validation schemas, keeping documentation and behaviour in step.
DATA, CACHE AND BACKGROUND WORK		
ioredis	5.x	Redis client for cache, sessions, rate limiting and idempotency.
bullmq	5.x	Background job queues with retries, back-off, scheduling and dead-letter handling.
node-cron	3.x	Recurring schedule definitions for the scheduler process.
migrate-mongo	11.x	Versioned, repeatable database migrations applied through the deployment pipeline.
REAL-TIME		
socket.io	4.x	WebSocket server for live order updates, notifications and messaging.
@socket.io/redis-adapter	8.x	Broadcasts real-time events across all server instances.
THIRD-PARTY SERVICE CLIENTS		
razorpay	2.x	Official payment gateway client — orders, captures, refunds, settlements.
@aws-sdk/client-s3	3.x	Object storage operations.

PACKAGE	VERSION	PURPOSE
@aws-sdk/s3-request-presigner	3.x	Issues time-limited signed URLs for private documents.
@aws-sdk/client-ses	3.x	Transactional email dispatch.
@aws-sdk/client-secrets-manager	3.x	Loads credentials at process start.
@aws-sdk/client-textract	3.x	Optical character recognition for seller KYC document field extraction.
firebase-admin	13.x	Push notification dispatch to mobile applications.
web-push	3.x	Browser push notifications for the web application.
nodemailer	7.x	Email transport abstraction, allowing the email provider to be changed without code changes.
axios	1.x	HTTP client for outbound calls to logistics, verification and taxation providers.
axios-retry	4.x	Automatic retry with back-off for transient third-party failures.
DOCUMENTS AND MEDIA		
pdfkit	0.18.x	Generates invoices, credit notes, manifests and settlement statements.
exceljs	4.x	Generates Excel exports for reporting.
fast-csv	5.x	CSV export and bulk catalogue import parsing.
sharp	0.33.x	Image resizing, format conversion, compression and metadata stripping.
qrcode	1.5.x	Generates authenticity and verification QR codes.
multer	2.x	Handles multipart file uploads before transfer to object storage.
OBSERVABILITY		
pino	9.x	Structured JSON logging.
pino-http	10.x	Automatic request and response logging with correlation identifiers.
@sentry/node	10.x	Exception capture, grouping and release tracking.
prom-client	15.x	Application metrics for operational dashboards and alerting.
UTILITIES		

PACKAGE	VERSION	PURPOSE
date-fns	4.x	Date arithmetic and formatting, including timezone handling for India Standard Time.
slugify	1.6.x	Generates URL-safe identifiers for products, categories and articles.
nanoid	5.x	Short unique identifiers for order numbers, referral codes and authenticity codes.
decimal.js	10.x	Exact decimal arithmetic for tax, commission and settlement calculations.
i18next	24.x	Server-side message translation for emails, SMS and notifications.
compression	1.7.x	Response compression.

4.2 Backend development packages

Used to build, test and maintain the codebase. Not deployed to production.

PACKAGE	VERSION	PURPOSE
vitest	2.x	Unit and integration test runner.
supertest	7.x	HTTP-level API endpoint testing.
mongodb-memory-server	10.x	Runs an ephemeral in-memory MongoDB instance for isolated, repeatable tests.
@faker-js/faker	9.x	Generates realistic test and seed data.
eslint	9.x	Static analysis for correctness and consistency.
typescript-eslint	8.x	TypeScript-aware linting rules.
prettier	3.x	Automatic, non-negotiable code formatting.
husky	9.x	Git hooks that run checks before a commit is accepted.
lint-staged	15.x	Runs linting and formatting only on changed files.
commitlint	19.x	Enforces a consistent commit-message convention for readable history.
@types/*	—	TypeScript type definitions for libraries that do not ship their own.

4.3 Frontend packages

Shared across the storefront, seller portal and admin panel.

PACKAGE	VERSION	PURPOSE
CORE		
react	19.x	User interface library.
react-dom	19.x	Browser rendering, including the server-rendering entry point for the storefront.
react-router-dom	7.x	Routing with route-level code splitting.
vite	6.x	Development server and production build tooling.
@vitejs/plugin-react	4.x	React integration for the build pipeline.
STATE AND DATA		
@tanstack/react-query	5.x	Server state: caching, background refresh, deduplication, optimistic updates.
zustand	5.x	Local client state — cart preview, interface preferences, theme, recently viewed.
axios	1.x	HTTP client with interceptors for token attachment and automatic refresh.
socket.io-client	4.x	Real-time connection for live updates and messaging.
INTERFACE AND DESIGN SYSTEM		
tailwindcss	3.x	Utility-first styling driven by brand design tokens.
@radix-ui/react-*	1.x-2.x	Accessible interface primitives — dialog, dropdown, select, tabs, tooltip, accordion, popover, toast and others. These provide the keyboard and screen-reader behaviour required for WCAG 2.1 AA.
class-variance-authority	0.7.x	Type-safe component style variants.
tailwind-merge	2.x	Resolves conflicting utility classes predictably.
lucide-react	0.4xx	Icon set.
embla-carousel-react	8.x	Accessible carousels for product galleries and homepage merchandising.
FORMS AND VALIDATION		
react-hook-form	7.x	Form state and validation with minimal re-rendering.
@hookform/resolvers	3.x	Connects form validation to the shared Zod schemas.
zod	3.x	Validation schemas, shared with the server.
CONTENT, REPORTING AND LOCALE		

PACKAGE	VERSION	PURPOSE
i18next	24.x	Translation engine.
react-i18next	15.x	React bindings for translation, with the English and Hindi toggle.
recharts	2.x	Charts for the admin and seller analytics dashboards.
@tiptap/react	2.x	Rich-text editing for product descriptions, blog articles and heritage content.
@tanstack/react-table	8.x	Sortable, filterable, paginated data tables for the back-office panels.
react-day-picker	9.x	Date selection for the events calendar and reporting filters.
date-fns	4.x	Date formatting and arithmetic.
PERFORMANCE AND SEARCH-ENGINE VISIBILITY		
react-helmet-async	2.x	Per-page titles, meta descriptions, canonical URLs and structured data.
web-vitals	4.x	Measures real-user performance against Core Web Vitals thresholds.
@sentry/react	10.x	Client-side error capture with session context.

4.4 Shared contract package

An internal package imported by the server, all three web surfaces and the mobile applications. It is the single definition of the platform's vocabulary, and it is the mechanism by which the client and server cannot drift apart.

CONTENTS	PURPOSE
Enumerations	Every fixed value set in the system — order statuses, payment statuses, seller verification states, product statuses, return states, notification types, user roles, ticket priorities and the rest. Defined once, used everywhere.
Validation schemas	Zod schemas for every request and response. The server validates against them; the client builds its forms from them. A field cannot be added on one side and forgotten on the other.
Type definitions	TypeScript interfaces for every entity exchanged over the API.
Error codes	A stable catalogue of machine-readable error codes, so clients can respond to specific conditions and support staff can identify a fault from a code alone.
Event contracts	The payload shape of every real-time and background event, so producers and consumers agree.

4.5 Mobile application packages

PACKAGE	VERSION	PURPOSE
expo	52.x	React Native application framework, build system and native module layer.
react-native	0.76.x	Native rendering for iOS and Android.
expo-router	4.x	File-based navigation with deep-link support.
expo-notifications	0.29.x	Push notification registration, receipt and handling.
expo-secure-store	14.x	Encrypted storage for authentication tokens in the device keychain.
react-native-razorpay	2.x	Native payment checkout with UPI intent support.
@tanstack/react-query	5.x	Shared data layer, identical to the web application.
nativewind	4.x	Tailwind styling for React Native, reusing the web design tokens.
expo-image	2.x	Performant image rendering with caching.
expo-localization	16.x	Device locale detection for the English and Hindi toggle.

SECTION 5

Development & Delivery Tooling

The tools used to build, verify, deploy and operate the platform. These are working instruments rather than parts of the shipped product, but they determine the quality and repeatability of what is shipped.

5.1 Source control and collaboration

TOOL	PURPOSE
Git	Version control for all source code, configuration and documentation.
GitHub	Repository hosting, pull requests, code review, issue tracking and automation. Branch protection prevents unreviewed code reaching the main branch.
Conventional Commits	A commit-message convention that makes history readable and allows release notes to be generated automatically.

5.2 Local development environment

Every developer runs the full platform locally through Docker Compose, so that development conditions match production and no work depends on a shared environment being available.

SERVICE	SUBSTITUTES FOR
MongoDB (replica set)	MongoDB Atlas. Configured as a replica set locally so that transaction behaviour matches production exactly.
Redis	ElastiCache — cache, queues, sessions and rate limiting.
MinIO	AWS S3. Provides an S3-compatible interface so no developer needs live cloud credentials.
Mailhog	The email provider. Captures all outbound email in a local inbox so that templates can be reviewed and no test email reaches a real recipient.
Mongo Express	Atlas data browser, for local inspection.

WHY THIS MATTERS

Because the local environment is complete, a developer can build and test payment, upload, notification and queue behaviour without touching any live third-party service. That reduces the number of production credentials that must exist, limits how widely they are distributed, and means development is not blocked while a Company-owned account is being opened.

5.3 Code quality tooling

TOOL	ENFORCED AT
TypeScript compiler	Type correctness, checked on every commit and every build. A type error fails the build.
ESLint	Correctness and consistency rules, checked on commit and in the pipeline.
Prettier	Formatting, applied automatically on commit. Removes formatting from code review entirely.
Husky + lint-staged	Runs the above on changed files before a commit is accepted, so faults are caught before they reach the repository.
Commitlint	Commit message format.

5.4 Testing tooling

LAYER	TOOL	COVERAGE
Unit	Vitest	Individual functions and services in isolation — pricing, tax computation, commission calculation, state transitions, validation.
Integration	Vitest + Supertest + in-memory MongoDB	Complete API endpoints against a real database, covering authentication, authorisation, validation and persistence.
Component	Vitest + React Testing Library	Interface components, including keyboard interaction and accessible naming.
End-to-end	Playwright	Full journeys through a real browser — registration, search, add to cart, guest checkout, order placement, returns, seller listing submission, admin verification.
Accessibility	axe-core within Playwright	Automated WCAG 2.1 AA checks on every page, supported by manual keyboard and screen-reader review.
Load	k6	Behaviour under concurrent traffic on catalogue, search and checkout paths.
Security	npm audit, Snyk, OWASP ZAP	Dependency vulnerability scanning and automated application security scanning, ahead of the formal penetration test described in Section 12.

5.5 API design and documentation

TOOL	PURPOSE
OpenAPI 3.1	The formal API specification, generated from the validation schemas so it cannot describe behaviour the server does not implement.
Swagger UI	Browsable, executable API documentation for developers and integration partners.

TOOL	PURPOSE
Postman	Shared request collections for manual verification and for Company-side acceptance testing.

5.6 Database tooling

TOOL	PURPOSE
MongoDB Compass	Visual data inspection, query construction and index performance analysis.
mongosh	Command-line shell for administration and diagnostics.
migrate-mongo	Versioned schema and data migrations, applied automatically during deployment and reversible.
Atlas Performance Advisor	Identifies slow queries and recommends indexes against real production usage.

5.7 Build, deployment and operations

TOOL	PURPOSE
Docker	Container images for the API, worker and scheduler processes. The same image runs in every environment.
Docker Compose	Local orchestration of the full service set.
GitHub Actions	Continuous integration and deployment: type check, lint, test, security scan, build image, deploy. No change reaches an environment without passing every gate.
Terraform	Infrastructure defined as code, so environments are reproducible and infrastructure change is reviewed like application change.
AWS CloudWatch	Log aggregation, metrics and alarms.
Sentry	Exception tracking across server, web and mobile, grouped by release.
Grafana	Operational dashboards over application and infrastructure metrics.
UptimeRobot	External availability monitoring with alerting.

5.8 Design and content tooling

TOOL	PURPOSE
Figma	Interface design, design-token definition and developer handoff. The source of truth for visual design.

TOOL	PURPOSE
Storybook	An isolated catalogue of every interface component and its states, used for design review and as living documentation of the component library.

SECTION 6

Third-Party Integrations

Every external service the platform connects to, what it powers, what it requires, and who is responsible for providing it. Each entry is marked with its ownership and its criticality.

Legend

MARKER	MEANING
REQUIRED	The platform cannot go live without it.
OPTIONAL	Enhances the platform; can be added after launch without rework.
UNDER REVIEW	Subject to a feasibility assessment; not committed.
Company-owned	Requires a legal entity, KYC, a bank account or a commercial agreement. Only the Company can open the account.
Team-owned	Technical infrastructure provisioned and configured by the Development Team, typically under a Company-held billing account.

6.1 Payments

Razorpay — Payment Gateway		REQUIRED
PURPOSE	Collects all customer payments and processes all refunds.	
POWERS	UPI, net banking, credit and debit cards, and wallets, on both web and mobile. Also refunds, partial refunds against returns, and payment reconciliation.	
OWNERSHIP	Company-owned. The merchant account must be held in the Company's legal name; settlements are paid to the Company's bank account.	
CREDENTIALS	Key identifier, key secret, and webhook signing secret — one set for the test environment and one for production.	
COMPANY PROVIDES	Certificate of incorporation, company PAN, GSTIN, cancelled cheque or bank statement, director identity and address proof, and the business website URL.	
ONBOARDING	1. Open a Razorpay account in the Company's name. 2. Complete business KYC and await activation. 3. Publish the policy pages Razorpay requires before activation — terms of service, privacy policy, refund and cancellation policy, shipping policy and contact details. 4. Issue test-mode keys so integration can begin immediately. 5. Configure the webhook endpoint and capture the signing secret. 6. Enable the payment methods in scope. 7. Complete test-mode transaction testing across every method. 8. Issue live keys and perform controlled production verification.	
NOTES	Test-mode keys are issued quickly and are not dependent on KYC completion, so payment integration is never blocked. Razorpay Route should be evaluated during discovery: it allows a single customer payment to be split automatically between the Company and the seller at settlement, which materially simplifies the marketplace settlement flow. If Route is adopted, sellers complete a Razorpay sub-merchant KYC as part of onboarding.	

WEBHOOK RELIABILITY

Payment confirmation is never inferred from the customer's browser returning to a success page — a customer may close the browser, lose connectivity, or complete payment in a banking application that never returns. Confirmation is taken from Razorpay's server-to-server webhook, whose signature is verified against the exact raw request body. Every webhook is recorded on receipt, de-duplicated, and processed asynchronously, so a delivery received twice is never applied twice.

6.2 Logistics and shipping

The Scope of Work names four carriers with live tracking. Each requires a separate commercial account held by the Company. The platform integrates them behind a single internal carrier interface, so that adding, replacing or re-prioritising a carrier does not alter order or fulfilment logic.

Delhivery		REQUIRED
PURPOSE	Nationwide parcel logistics with wide pin-code coverage.	
POWERS	Serviceability checks, shipment creation, label generation, pickup scheduling, live tracking, and return pickups.	
OWNERSHIP	Company-owned — commercial account and rate agreement.	
CREDENTIALS	API token, client name, and registered pickup location identifiers, for staging and production.	
COMPANY PROVIDES	Signed commercial agreement, registered pickup addresses, and confirmed rate card.	
ONBOARDING	1. Commercial agreement and rate negotiation. 2. Account activation and staging credential issue. 3. Register pickup locations. 4. Integrate and test shipment creation, label generation and tracking in staging. 5. Configure tracking webhooks. 6. Production credential issue and live test consignment.	

Blue Dart		REQUIRED
PURPOSE	Premium express logistics, appropriate for high-value consignments.	
POWERS	Waybill generation, pickup registration, tracking, and delivery confirmation.	
OWNERSHIP	Company-owned.	
CREDENTIALS	Licence key, login identifier, and customer code, for staging and production.	
COMPANY PROVIDES	Corporate account agreement and registered origin addresses.	
ONBOARDING	1. Corporate account opening. 2. Request API access and staging credentials. 3. Integrate waybill generation and tracking. 4. Complete the carrier's certification testing. 5. Production credential issue.	
NOTES	Blue Dart applies a formal certification step before granting production access. This is a sequencing dependency and is best initiated early.	

DTDC

REQUIRED

PURPOSE	Broad domestic coverage, including tier-two and tier-three locations relevant to artisan pickup.
POWERS	Consignment booking, label generation, tracking, and pickup requests.
OWNERSHIP	Company-owned.
CREDENTIALS	API key, customer code, and access token.
COMPANY PROVIDES	Corporate account and rate agreement.
ONBOARDING	1. Corporate account opening. 2. API access request. 3. Integration against the test endpoint. 4. Production credential issue and live verification.

India Post

REQUIRED

PURPOSE	Reaches pin codes no private carrier serves — directly relevant for artisan clusters in remote regions.
POWERS	Booking, tracking, and pin-code serviceability lookup.
OWNERSHIP	Company-owned — Department of Posts business account.
CREDENTIALS	Business customer identifier and API credentials.
COMPANY PROVIDES	Business parcel account registration with the Department of Posts.
ONBOARDING	1. Register a business parcel account. 2. Apply for API access. 3. Integrate booking and tracking. 4. Live verification.
NOTES	India Post's interfaces are less uniform than the private carriers'. Where a capability is unavailable, the platform falls back to manual consignment entry with tracking reference capture, which is accommodated in the carrier interface design.

RECOMMENDED ALTERNATIVE: AGGREGATOR-FIRST

An aggregator such as Shiprocket or NimbusPost provides all four carriers through a single integration, a single reconciliation surface and a single support relationship, and typically offers negotiated rates without individual carrier agreements. This reduces four onboarding tracks to one and removes four separate credential sets. Direct carrier integrations can then be added selectively where rates or service levels justify them. We recommend evaluating this during discovery; the carrier interface described above supports either approach without rework.

6.3 Quick-commerce channels

Swiggy Instamart · Blinkit · Zepto		UNDER REVIEW
PURPOSE	Rapid-delivery distribution for a selected subset of the catalogue.	
OWNERSHIP	Company-owned — each requires a separate commercial seller relationship.	
STATUS	Subject to a feasibility review and not committed . These platforms operate a dark-store model with their own inventory placement, catalogue formats, service-level obligations and commercial terms. They are seller channels rather than shipping carriers, and integrating with them is a distinct commercial and operational undertaking.	
FEASIBILITY INPUTS	Which product classes suit rapid delivery given fragility and value; whether inventory is consigned to dark stores or fulfilled from seller locations; each platform's onboarding criteria and commercial terms; and whether partner API access is available at the Company's account tier.	
RECOMMENDATION	Assess after the core marketplace is operating. The platform's catalogue and inventory model is designed to support channel-specific distribution, so this can be added later without structural change.	

6.4 Communications

Transactional Email — AWS SES		REQUIRED
PURPOSE	All outbound email.	
POWERS	Account verification, password reset, order confirmation, dispatch and delivery notices, invoices, return and refund updates, seller verification decisions, payout statements, and administrative alerts.	
OWNERSHIP	Team-owned infrastructure, on a Company-owned domain.	
CREDENTIALS	Access key, secret key, and verified sending domain identity.	
COMPANY PROVIDES	DNS control for the sending domain, and the sending addresses to be used.	
ONBOARDING	1. Verify the sending domain by publishing DNS records. 2. Publish SPF, DKIM and DMARC records for deliverability. 3. Request removal from the sandbox, which limits sending until granted. 4. Configure bounce and complaint handling. 5. Warm the sending reputation gradually before launch volume.	
NOTES	Sandbox removal is a manual review by the provider and is a dependency worth initiating early. The email layer is abstracted, so SendGrid or another provider can be substituted by configuration alone.	

SMS — MSG91 (or Twilio)

REQUIRED

PURPOSE	One-time passwords and transactional SMS.
POWERS	Phone-number sign-in, phone verification, order and dispatch alerts, and delivery notifications.
OWNERSHIP	Company-owned.
CREDENTIALS	Authentication key, registered sender identifier, and approved template identifiers.
COMPANY PROVIDES	Company PAN and GSTIN, a letter of authorisation, and completion of TRAI DLT registration as described below.
ONBOARDING	1. Register the Company as a Principal Entity on a TRAI-approved DLT portal. 2. Register a six-character sender identifier. 3. Register the content template for every distinct message the platform sends, each with its variable fields. 4. Await approval of entity, sender and templates. 5. Open the SMS provider account and link the approved DLT registrations. 6. Integrate and test. 7. Move to production.

CRITICAL DEPENDENCY — TRAI DLT REGISTRATION

Under Indian telecom regulation, transactional SMS cannot be delivered unless the sending entity, the sender identifier and *the exact text of every message template* are pre-registered and approved on a Distributed Ledger Technology platform. Unregistered messages are blocked by the carriers, not merely delayed.

This has two consequences. First, registration is a Company obligation requiring Company documents — the Development Team cannot perform it. Second, every message template must be finalised and approved *before* phone-based sign-in and SMS notification can function in production. **This is the single most commonly underestimated dependency in an Indian e-commerce launch and should be initiated at the earliest opportunity.** A change to message wording after approval requires re-registration and re-approval.

Push Notifications — Firebase Cloud Messaging

REQUIRED

PURPOSE	Push notifications to the mobile applications and to web browsers.
POWERS	Order status updates, dispatch and delivery alerts, promotional campaigns, new-arrival announcements, and seller alerts.
OWNERSHIP	Team-owned project under a Company-owned Google account.
CREDENTIALS	Firebase service account key, Android configuration file, iOS configuration file, and an Apple Push Notification authentication key.
COMPANY PROVIDES	A Google account for project ownership, and Apple Developer Program access for the push authentication key.
ONBOARDING	1. Create the Firebase project. 2. Register the Android and iOS applications. 3. Generate the Apple push authentication key in the Apple Developer account and upload it to Firebase. 4. Generate web push keys for browser notifications. 5. Integrate and test on physical devices.
NOTES	iOS push requires a paid Apple Developer Program membership and cannot be tested on the iOS simulator — physical device testing is necessary.

WhatsApp Business API

OPTIONAL

PURPOSE	Order updates and customer support over WhatsApp, which typically achieves substantially higher engagement than SMS in the Indian market.
OWNERSHIP	Company-owned — through Meta directly or an approved business solution provider.
COMPANY PROVIDES	Verified Meta Business account, a dedicated phone number, and approved message templates.
ONBOARDING	1. Verify the Meta Business account. 2. Register a dedicated number. 3. Submit message templates for approval. 4. Integrate through the chosen provider.
NOTES	Not named in the Scope of Work. The notification layer is channel-abstracted, so WhatsApp can be added later as an additional channel without altering notification logic.

6.5 Identity and sign-in

Google Sign-In (OAuth 2.0)		REQUIRED
PURPOSE	Single sign-on with a Google account, named explicitly in the Scope of Work.	
OWNERSHIP	Team-configured under a Company-owned Google Cloud project.	
CREDENTIALS	OAuth client identifier and client secret, for web, Android and iOS.	
COMPANY PROVIDES	Google Cloud project ownership, verified domain, and published privacy policy and terms of service URLs.	
ONBOARDING	1. Create the Google Cloud project. 2. Configure the OAuth consent screen with brand name, logo, and policy links. 3. Create client credentials for each platform. 4. Register authorised redirect URIs. 5. Submit for verification, required for a public consent screen. 6. Integrate and test.	
NOTES	Google's consent-screen verification is a manual review and must be complete before public launch. It requires the privacy policy to be live at a verified domain.	

Facebook Login		REQUIRED
PURPOSE	Single sign-on with a Facebook account, named explicitly in the Scope of Work.	
OWNERSHIP	Company-owned Meta Business account and application.	
CREDENTIALS	Application identifier and application secret.	
COMPANY PROVIDES	Verified Meta Business account, business verification documents, and published privacy policy and data deletion instructions.	
ONBOARDING	1. Create the Meta application. 2. Complete Business Verification with Company documents. 3. Configure Facebook Login and redirect URIs. 4. Publish a data deletion callback, which Meta requires. 5. Submit for App Review to obtain the permissions needed for public use. 6. Integrate and test.	
NOTES	Meta's Business Verification and App Review are manual processes that can require resubmission. Both should be initiated early, as neither is within the Development Team's control.	

6.6 Cloud, storage and delivery

MongoDB Atlas		REQUIRED
PURPOSE	The platform's primary database, as a managed service.	
POWERS	All persistent data, together with catalogue search through Atlas Search.	
OWNERSHIP	Company-owned organisation; Team-configured clusters.	
CREDENTIALS	Connection strings and database user credentials, per environment.	
COMPANY PROVIDES	Account ownership and billing.	
ONBOARDING	1. Create the Atlas organisation under a Company account. 2. Provision clusters in the Mumbai (ap-south-1) region — this is a data residency requirement, not a preference. 3. Configure network access restricted to application infrastructure. 4. Create least-privilege database users per environment. 5. Enable encryption at rest and continuous backup with point-in-time recovery. 6. Configure Atlas Search indexes. 7. Enable monitoring and alerting.	

Amazon Web Services		REQUIRED
PURPOSE	Application hosting, object storage, content delivery, email, secrets management and document processing.	
POWERS	ECS for compute, S3 for storage, CloudFront for delivery, SES for email, ElastiCache for Redis, Secrets Manager for credentials, Textract for document extraction, CloudWatch for logs and metrics.	
OWNERSHIP	Company-owned account; Team-configured resources.	
CREDENTIALS	Identity and access management roles and policies, scoped to least privilege per service.	
COMPANY PROVIDES	AWS account ownership and billing.	
ONBOARDING	1. Create the account with the root user secured by hardware two-factor authentication. 2. Configure organisational structure and billing alerts. 3. Create least-privilege roles for deployment and runtime. 4. Provision all resources in the Mumbai (ap-south-1) region. 5. Enable CloudTrail audit logging. 6. Configure backup and lifecycle policies.	
NOTES	Every resource is provisioned in an India region without exception, for the data residency reasons in Section 12.	

Cloudflare		REQUIRED
PURPOSE	Edge protection and DNS.	
POWERS	DNS management, web application firewall, bot management, denial-of-service protection, and edge caching.	
OWNERSHIP	Company-owned account and domain; Team-configured rules.	
COMPANY PROVIDES	Domain registrar access to change nameservers.	
ONBOARDING	1. Add the domain to Cloudflare. 2. Update nameservers at the registrar. 3. Configure DNS records for all environments. 4. Enable the web application firewall with a managed rule set. 5. Configure bot management and rate-limiting rules. 6. Enforce TLS 1.3.	

6.7 Taxation and invoicing

GST Compliance & E-Invoicing		REQUIRED
PURPOSE	Produces GST-compliant invoices and the automated GST reporting required by the Scope of Work.	
POWERS	Tax computation at the line level; correct application of CGST, SGST and IGST according to the supply route; separate vendor-GST and consumer-GST invoice categorisation; HSN classification; credit notes against returns; and category-wise GST reporting.	
OWNERSHIP	Company-owned — GST registration and any ASP or GSP relationship.	
COMPANY PROVIDES	Company GSTIN and registered place of business; the HSN code and GST rate for every product category ; the marketplace tax position, including TCS applicability under Section 52 of the CGST Act; invoice numbering series and format; and the registered invoice footer and signatory details.	
ONBOARDING	1. The Company's tax advisor confirms the marketplace tax treatment and TCS position in writing. 2. The Company supplies the complete HSN and rate mapping for every category. 3. The tax engine is implemented and its output verified against the advisor's worked examples. 4. If e-invoicing applies, an ASP or GSP provider is appointed and integrated for Invoice Registration Portal submission. 5. Invoice templates are approved by the Company. 6. Reporting output is reconciled against the Company's filing requirements.	

THIS IS A BUSINESS INPUT, NOT A TECHNICAL ONE

The platform can compute any tax rule correctly, but it cannot determine what the rule is. Marketplace GST treatment — place of supply, TCS collection and reporting under Section 52, whether the platform or the seller is the supplier of record for each product class, and the e-invoicing threshold applicable to each seller — is a determination for the Company's tax advisors.

This determination is required before invoicing and settlement can be built. It is not a matter that can be resolved during testing, because an incorrect tax position produces documents that are legally defective rather than merely inaccurate. Section 8 lists the specific inputs required.

6.8 Seller verification and KYC

GSTIN Verification

REQUIRED

PURPOSE	Confirms that a seller's declared GSTIN is valid, active, and registered to the declared legal name.
OWNERSHIP	Company-owned account with a verification provider such as Karza, Signzy or Surepass.
COMPANY PROVIDES	Provider account and commercial agreement.
ONBOARDING	1. Select and contract a provider. 2. Complete provider KYC. 3. Obtain sandbox credentials and integrate. 4. Move to production credentials.
NOTES	Without this, GSTIN validation is manual — which is workable at low seller volume but does not scale, and leaves the vendor-GST invoice categorisation resting on unverified data.

Bank Account Verification (Penny Drop)

REQUIRED

PURPOSE	Confirms a seller's bank account exists and that the account holder name matches the registered seller, before any payout is made.
OWNERSHIP	Company-owned — available through the same verification provider, or through Razorpay.
ONBOARDING	1. Enable the capability with the provider. 2. Integrate into seller onboarding. 3. Test against real accounts in a controlled manner.
NOTES	This directly prevents misdirected settlements. A payout sent to an incorrect account is difficult and sometimes impossible to recover, so verification at onboarding is materially cheaper than remediation later.

PAN Verification

REQUIRED

PURPOSE	Validates seller PAN for tax deduction and reporting obligations.
OWNERSHIP	Company-owned , through the same verification provider.
ONBOARDING	Enabled alongside GSTIN verification under the same provider agreement.

Document OCR — AWS Textract

OPTIONAL

PURPOSE	Extracts fields automatically from uploaded seller KYC documents and GI certificates.
POWERS	Pre-populates the reviewer's screen with extracted values, so verification becomes confirmation rather than transcription.
OWNERSHIP	Team-configured under the Company AWS account.
NOTES	An efficiency measure for the verification team, not a control. Every extracted field remains subject to human confirmation — automated extraction never approves a seller or a certificate.

GI Registry of India

MANUAL PROCESS

PURPOSE	Authoritative confirmation that a GI registration exists and that the seller is a registered proprietor or authorised user.
STATUS	No public API is available. Verification is performed manually by the Company's GI verification officer against the Registry's published records.
PLATFORM SUPPORT	The platform supports this manual process rather than replacing it: it maintains a reference list of GI registrations, categories and regions; presents the seller's submitted certificate alongside the claim; records the officer's decision with structured reasons; retains the evidence; and maintains a full audit trail of who decided what and when.
COMPANY PROVIDES	A named GI verification officer, and the verification criteria that officer applies.

6.9 Maps and address

Google Maps Platform		REQUIRED
PURPOSE	Address entry, validation and geographic display.	
POWERS	Address autocomplete at checkout, pin-code validation and lookup, geocoding for logistics, and the map view of GI regions of origin.	
OWNERSHIP	Company-owned Google Cloud billing account; Team-configured keys.	
CREDENTIALS	API keys, separately restricted for web, Android and iOS.	
ONBOARDING	1. Enable the Places, Geocoding and Maps JavaScript APIs. 2. Create per-platform keys with referrer and application restrictions. 3. Set usage quotas and billing alerts. 4. Integrate.	
NOTES	Keys are restricted by referrer or application signature so that a leaked key cannot be used elsewhere. Quotas are capped to bound exposure. Address autocomplete measurably reduces checkout abandonment and delivery failure from mistyped addresses.	

6.10 Analytics

Google Analytics 4		REQUIRED
PURPOSE	Traffic and behaviour analytics, supporting the traffic reporting in the Scope of Work.	
POWERS	Acquisition channels, audience behaviour, and the e-commerce funnel from product view through to purchase.	
OWNERSHIP	Company-owned property.	
ONBOARDING	1. Create the property. 2. Configure e-commerce events and conversions. 3. Integrate across web and mobile. 4. Link to Google Search Console. 5. Configure consent handling.	
NOTES	Analytics collection is subject to the consent mechanism described in Section 12. Sales and revenue reporting is computed from the platform's own records, not from analytics — analytics measures behaviour, the platform measures transactions.	

Mixpanel · Hotjar

OPTIONAL

PURPOSE	Product analytics and session behaviour analysis.
POWERS	Funnel and retention analysis; heatmaps and session recordings for conversion optimisation.
OWNERSHIP	Company-owned.
NOTES	Valuable once meaningful traffic exists. If adopted, session recording must mask all personal and payment fields, and its use must be disclosed in the privacy policy.

6.11 Security and anti-abuse

Google reCAPTCHA v3 (or Cloudflare Turnstile)

REQUIRED

PURPOSE	Protects public endpoints from automated abuse.
POWERS	Registration, sign-in, password reset, OTP request, review submission and contact forms — each a target for automated attack or fraudulent submission.
OWNERSHIP	Team-configured under a Company account.
NOTES	Protecting the OTP request endpoint is particularly important: unprotected, it can be driven at volume to generate SMS cost and to harass phone-number holders.

CERT-In Empanelled VAPT Auditor

REQUIRED

PURPOSE	Independent vulnerability assessment and penetration testing before go-live and before major releases, as required by the agreement.
OWNERSHIP	Company-appointed. The auditor must be independent of the Development Team and empanelled with CERT-In.
COMPANY PROVIDES	Appointment of the auditor and the engagement agreement.
ONBOARDING	1. The Company appoints a CERT-In empanelled auditor. 2. The Development Team provides a dedicated test environment, documentation and test credentials. 3. The audit is conducted. 4. Findings are remediated by the Development Team. 5. The auditor re-tests and issues a clearance certificate. 6. Go-live proceeds.
NOTES	This is a gating dependency for launch. Appointing the auditor early allows the assessment window to be scheduled without becoming the constraint on go-live.

6.12 Monitoring and error tracking

Sentry		REQUIRED
PURPOSE	Captures and groups every unhandled error across server, web and mobile.	
POWERS	Error alerting with full context, release tracking, and regression detection — so faults are identified from telemetry rather than from customer complaints.	
OWNERSHIP	Company-owned account; Team-configured .	
NOTES	Personal data is scrubbed before transmission. Configured to retain data within permitted regions consistent with Section 12.	

UptimeRobot (or equivalent)		REQUIRED
PURPOSE	External availability monitoring, independent of the platform's own infrastructure.	
POWERS	Checks the storefront, API and critical endpoints from outside the hosting environment, alerting on failure.	
NOTES	Internal monitoring cannot report an outage that has taken the monitoring with it. External checking is what detects a total failure.	

6.13 App store distribution

Apple Developer Program		REQUIRED
PURPOSE	iOS application distribution and push notification capability.	
OWNERSHIP	Company-owned. Enrolment must be in the Company's legal name; an application published under a developer's personal account cannot be transferred cleanly and creates a lasting dependency.	
COMPANY PROVIDES	Legal entity name, D-U-N-S number, and an authorised signatory.	
ONBOARDING	1. Obtain a D-U-N-S number for the Company. 2. Enrol in the Apple Developer Program as an organisation. 3. Await Apple's verification. 4. Create the application record, certificates and provisioning profiles. 5. Configure App Store Connect metadata. 6. Submit for review.	
NOTES	Organisation enrolment requires D-U-N-S issuance and Apple verification, both outside the Development Team's control. App Review can require resubmission. Both should be initiated well before the application is ready.	

Google Play Console

REQUIRED

PURPOSE Android application distribution.

OWNERSHIP **Company-owned** organisation account.

COMPANY PROVIDES Organisation details, D-U-N-S number, and a payment profile.

ONBOARDING **1.** Create the organisation developer account. **2.** Complete identity verification. **3.** Create the application and complete the data safety declaration. **4.** Configure signing. **5.** Submit for review.

NOTES The data safety declaration must accurately describe what the application collects and shares, and must remain consistent with the published privacy policy.

SECTION 7

Integration Onboarding Process

Every third-party service follows the same seven-stage onboarding path. Standardising it means each integration is predictable, testable and reversible, and that no service reaches production without verification.

7.1 The standard onboarding path

#	STAGE	WHAT HAPPENS	OWNER
1	Selection and agreement	The provider is confirmed and any commercial agreement executed. For alternatives, a short comparison is prepared against coverage, reliability and terms.	Company, advised by Team
2	Account opening and KYC	The account is opened in the Company's legal name and provider KYC is completed. Accounts are never opened in an individual's name.	Company
3	Sandbox credentials	Test credentials are issued and stored in the secrets manager. Integration work begins here, and is not blocked by production approval.	Company issues, Team stores
4	Integration behind an interface	The service is implemented behind an internal interface, never called directly from business logic. A logging stub is built alongside the real adapter.	Team
5	Sandbox verification	Success paths, failure paths, timeouts, malformed responses and webhook handling are all tested — including what the platform does when the service is unavailable.	Team
6	Production activation	Live credentials are issued, stored in the secrets manager, and enabled by configuration. No code change is required to move from sandbox to production.	Company issues, Team configures
7	Controlled production verification	A small number of real transactions are executed and verified end to end — a real payment, a real shipment, a real message — before the integration carries live volume.	Team, witnessed by Company

7.2 Why every integration sits behind an interface

No third-party service is called directly from business logic. Each sits behind an internal interface — a payment interface, a carrier interface, an email interface, an SMS interface. This yields four practical benefits:

- **Development is never blocked.** A logging stub satisfies the interface, so order, notification and fulfilment flows can be built and tested while a Company-owned account is still being opened.
- **Providers can be substituted.** Changing email provider, adding a carrier, or moving from direct carriers to an aggregator is a configuration change plus one new adapter, not a rewrite.

- **Failure is contained.** When a provider is unavailable, the interface applies the defined fallback — queue and retry, route to an alternate carrier, or degrade the feature — rather than propagating the failure into a customer transaction.
- **Testing is deterministic.** Automated tests run against stubs, so the test suite does not depend on a third party being reachable, and no test consumes live credits or dispatches real messages.

7.3 Credential handling policy

RULE	PRACTICE
Never in source control	No credential is ever committed. Automated secret scanning runs on every commit and blocks the push if a credential is detected.
Central secret storage	All production credentials are held in AWS Secrets Manager and loaded into the process at start. They are not present in configuration files or container images.
Separation by environment	Development, staging and production hold entirely separate credentials. A development credential can never reach a production system.
Least privilege	Each credential is scoped to only the operations it needs. Where a provider supports restricted keys, restricted keys are used.
Controlled handover	Credentials are transferred through a secure channel — never by email or messaging. A shared password manager vault is established for this purpose.
Rotation	Credentials are rotated on a defined schedule and immediately on any personnel change or suspected exposure. Rotation requires no code change.
Company retains ownership	Every account is owned by the Company. The Development Team holds delegated access, which can be revoked at any time without affecting the platform's operation.

7.4 Onboarding dependency summary

The following integrations involve external approval processes outside the Development Team's control. Each should be initiated at the earliest opportunity, because the approval, not the engineering, determines when the capability becomes available.

INTEGRATION	EXTERNAL PROCESS	CONSEQUENCE IF DELAYED
TRAI DLT registration	Entity, sender and per-template approval	Phone sign-in and all SMS notification are non-functional in production. Message wording must be final before submission.
Razorpay activation	Business KYC and policy page review	Live payments cannot be accepted. Test mode is unaffected, so build continues.
AWS SES sandbox removal	Provider review	Email sending is restricted to verified addresses only.

INTEGRATION	EXTERNAL PROCESS	CONSEQUENCE IF DELAYED
Google OAuth verification	Consent screen review	Google sign-in shows an unverified warning and is capped in reach.
Meta business verification and App Review	Two sequential manual reviews	Facebook sign-in cannot be used publicly.
Apple Developer enrolment	D-U-N-S issuance and Apple verification	The iOS application cannot be built for devices, tested with push, or submitted.
Blue Dart certification	Carrier integration certification	Production shipping through this carrier is unavailable.
CERT-In VAPT	Independent audit and re-test	Go-live cannot proceed; this is a launch gate.
GST determination	Company tax advisor opinion	Invoicing and settlement cannot be built correctly; documents produced without it may be legally defective.

SECTION 8

Requirements From the Company

A consolidated checklist of everything required from the Company. Items are grouped by type. Nothing here can be supplied by the Development Team, because each depends on the Company's legal identity, commercial relationships, brand or business judgement.

8.1 Legal entity and corporate documents

Required to open third-party accounts in the Company's name.

ITEM	NEEDED FOR	NOTES
Certificate of incorporation	Razorpay, carriers, verification providers	Standard KYC document.
Company PAN	Razorpay, SMS, carriers	—
GST registration certificate and GSTIN	Razorpay, invoicing, SMS, carriers	Also required for the tax engine.
Bank account details and cancelled cheque	Razorpay settlement	Settlement destination account.
Director or authorised signatory identity and address proof	Razorpay, Meta, Apple	—
D-U-N-S number	Apple Developer, Google Play	Free to obtain but issuance takes time; start early.
Letter of authorisation	SMS sender identifier registration	Provider-supplied format.
Registered office and place-of-business addresses	Invoicing, carrier pickup registration	—

8.2 Accounts to be opened

ACCOUNT	PRIORITY	BLOCKING EFFECT
Razorpay merchant account	Immediate	Test keys unblock all payment work; live keys required for launch.
TRAI DLT registration	Immediate	Longest external lead dependency in the project.
SMS provider account	Immediate	Depends on DLT registration.
AWS account	Immediate	All infrastructure depends on it.
MongoDB Atlas organisation	Immediate	All data storage depends on it.

ACCOUNT	PRIORITY	BLOCKING EFFECT
Google Cloud project	Immediate	Sign-in, Maps and Analytics.
Meta Business account	Early	Two sequential manual reviews.
Apple Developer Program	Early	Requires D-U-N-S first.
Google Play Console	Early	—
Cloudflare account	Early	Requires registrar access.
Carrier accounts — Delhivery, Blue Dart, DTDC, India Post	Early	Or a single aggregator account, per Section 6.2.
KYC verification provider	Before seller onboarding	GSTIN, PAN and bank verification.
Sentry account	Before staging	—
Google Analytics property	Before launch	—

8.3 Brand, content and creative assets

ASSET	USED FOR
Logo in vector format, with variants	All surfaces, invoices, emails, application icons, store listings.
Brand colour palette and typography	Design tokens driving the entire interface.
Brand guidelines, if they exist	Consistency across web, mobile and communications.
Application icons and store screenshots	Apple App Store and Google Play listings.
Photography and imagery library	Homepage, category pages, heritage and editorial content.
Tone-of-voice guidance	Interface copy, notifications, transactional email.
Hindi translations, or approval of ours	The English and Hindi toggle. Machine translation is not appropriate for heritage and cultural content.
Initial heritage and editorial content	The GI Tag, Traditions, blog and events modules require content at launch to be credible.

8.4 Legal and policy documents

These must be drafted or approved by the Company's legal advisors. Several are preconditions for third-party account activation, not merely site content.

DOCUMENT	REQUIRED BY
Terms of service	Razorpay activation; platform.
Privacy policy	Razorpay, Google OAuth, Meta, Apple, Google Play.
Refund and cancellation policy	Razorpay activation; consumer law.
Shipping and delivery policy	Razorpay activation.
Seller agreement	Seller onboarding.
Returns and exchange policy	Returns workflow configuration.
Grievance officer details	Consumer Protection (E-Commerce) Rules, 2020 — name, designation, contact and response process must be published.
Data deletion instructions	Meta App Review requirement.
Cookie and consent policy	Analytics consent handling.

8.5 Taxation inputs

REQUIRED BEFORE INVOICING AND SETTLEMENT CAN BE BUILT

- **HSN code and GST rate for every product category**, supplied as a complete mapping.
- **The marketplace tax position** — whether the platform or the seller is the supplier of record, per product class.
- **TCS applicability and rate** under Section 52 of the CGST Act, together with the reporting format required.
- **Place-of-supply rules** to be applied, determining CGST and SGST versus IGST.
- **Invoice numbering series and format**, separately for vendor-GST and consumer-GST categorisation.
- **E-invoicing applicability** and, if applicable, the appointed ASP or GSP provider.
- **TDS obligations** on seller payouts, with rates and thresholds.
- **A worked example of each invoice type**, approved by the Company's tax advisor, against which the platform's output is verified.

8.6 Domain and infrastructure access

ITEM	PURPOSE
Primary domain name	The platform's public address.
Domain registrar access	Nameserver delegation to Cloudflare.

ITEM	PURPOSE
DNS control	Email authentication records, subdomain configuration, verification records.
Subdomain naming decisions	API, seller portal, admin panel and asset delivery hostnames.
Company email addresses	Sending addresses, support address, grievance officer address.

8.7 Nominated points of contact

Each requires a named individual with authority to decide, not merely to relay:

ROLE	RESPONSIBLE FOR
Project sponsor	Scope and priority decisions; final acceptance.
Business owner	Day-to-day requirement clarification and business rule decisions.
Finance and tax contact	All Section 8.5 inputs; commission and settlement rules.
Legal and compliance contact	Section 8.4 documents; the grievance mechanism.
Content owner	Heritage content, editorial, translations, brand voice.
GI verification officer	The verification criteria applied to sellers and listings.
Operations contact	Carrier relationships, fulfilment rules, support process.
Acceptance testers	Validating each surface against the agreed requirements.

SECTION 9

Decisions Required Before Build

The Scope of Work leaves a number of matters unspecified that materially affect how the platform is built. Each is a business decision rather than a technical one. They are listed here so they can be settled during discovery and recorded in the requirements specification, rather than surfacing mid-build.

9.1 Seller lifecycle

The Scope of Work names four seller portal features — product listing, inventory management, order tracking and a payout dashboard. It does not describe how a seller comes to exist on the platform. The following must be decided:

DECISION	WHAT MUST BE SETTLED
Onboarding and KYC	How a seller applies, which documents are collected, and which are mandatory versus optional.
Approval workflow	Who reviews an application, on what criteria, and what the rejection and resubmission path is.
Listing moderation	Whether new listings go live immediately or await review; whether edits to an approved listing require re-approval; and whether the rule differs between GI-tagged and non-GI products.
Commission structure	Whether commission is flat, per category, per seller or tiered — and who may change it.
Settlement rules	When earnings become payable, the settlement cycle, how returns and refunds are offset, minimum payout thresholds, and the treatment of failed transfers.
Bulk upload	Whether sellers may upload catalogues in bulk, and in what format.
Suspension and offboarding	Grounds for suspension, its effect on live listings and open orders, and how outstanding balances are settled.

9.2 Administrative permission model

The Scope of Work specifies role-based access control with configurable permission levels, but does not enumerate the roles. “Configurable” describes a mechanism; it is not itself a permission model. Before build, the Company must name the administrative roles it actually requires and state what each may read and change. A typical set for a platform of this kind:

- **Super administrator** — full access, including settings and permission assignment.
- **Catalogue manager** — products, categories, inventory.
- **GI verification officer** — certificate and listing verification only.
- **Order and support agent** — orders, returns, tickets; restricted view of customer data.
- **Finance officer** — settlements, refunds, tax reporting.

- **Seller manager** — seller onboarding, approval, suspension.
- **Content editor** — blog, heritage content, events, banners.

This list is a starting point for discussion, not a recommendation to adopt as written.

9.3 Customer and guest behaviour

DECISION	WHAT MUST BE SETTLED
Guest order handling	Guest checkout is explicitly in scope. How a guest tracks an order without an account, where the invoice is delivered, and whether a guest order can later be claimed by a registered account, are all unspecified.
Guest invoicing	Every invoice must be GST-compliant. What a guest order captures for invoicing purposes, and how that invoice reaches the buyer, must be decided.
Review moderation	Whether reviews publish immediately or await approval; whether only verified purchasers may review; how a seller responds; and how a disputed review is handled. Reviews cover sellers as well as products.
Content gating	All heritage content is currently open to unauthenticated visitors. If any is intended to drive registration, that gate must be specified now, as it affects both search-engine visibility and traffic reporting.
Referral economics	What a referrer earns, what a referee receives, when credit is earned, how credit is redeemed, expiry, and anti-abuse limits.

9.4 Returns and grievance

DECISION	WHAT MUST BE SETTLED
Return window and eligibility	The return period, which product classes are eligible, and the acceptable reasons.
Return logistics	Whether returns are collected by carrier or returned by the customer, and who bears the cost under each reason.
Refund timing	Whether refunds issue on return initiation, on receipt, or on inspection — and the effect on seller settlement.
Exchange handling	Whether an exchange is a return plus a new order, or a distinct flow, and how price differences are handled.
Grievance workflow	The Consumer Protection (E-Commerce) Rules require a grievance mechanism. The queue, acknowledgement and resolution timelines, escalation path, and who staffs it must be defined.

9.5 Explicitly out of scope

For completeness: **memory games and in-house child development models are out of scope.** These require custom game development and are subject to separate scoping. Traditional learning content delivered as blog and content pages is included and is covered by the content management module described in Section 3.

SECTION 10

How We Will Proceed

The build proceeds in stages ordered by technical dependency — each stage produces something demonstrable, and each depends on the one before it. No durations are stated; sequence here means logical order, not schedule.

10.1 Stage sequence

Stage 0 — Discovery and specification

Before any code is written, the open matters in Section 9 are settled and recorded. This stage produces the Software Requirements Specification that governs the build.

- Workshops covering seller lifecycle, permission model, returns, grievance and referral economics.
- The taxation determination from the Company's advisors (Section 8.5).
- Complete data model and API contract definition.
- Interface design and design tokens in Figma, reviewed and approved.
- Third-party account opening initiated — particularly the long-lead items in Section 7.4.
- **Exit criterion:** a signed requirements specification and an approved design system.

Stage 1 — Foundation

The infrastructure every subsequent stage depends on. Nothing user-facing, but everything rests on it.

- Repository structure, shared contract package, coding standards, continuous integration pipeline.
- Local development environment via Docker Compose.
- Database connection, schema foundation and migration framework.
- Request pipeline: security headers, correlation, rate limiting, validation, error handling, response envelope.
- Authentication and the RBAC permission model.
- Cache, queue and scheduler infrastructure.
- Logging, error tracking and health checks.
- Component library and design system implementation.
- **Exit criterion:** a deployable application skeleton with working authentication, deployed to staging through the pipeline.

Stage 2 — Catalogue and content model

- Categories, products, variants, inventory and media handling.
- The three product classes and their distinct attribute sets.
- GI region, GI category and certificate reference data.
- Search indexing and the faceted filter set.
- Public storefront: catalogue, category, product detail and search, server-rendered.
- **Exit criterion:** a browsable, searchable, indexable catalogue populated with real data.

Stage 3 — Commerce

- Cart, including guest cart and its merge behaviour on sign-in.
- Address management with validation.
- Multi-step checkout and guest checkout.
- Payment integration and webhook confirmation.
- Tax computation and invoice generation.
- Order lifecycle, status transitions and history.
- Shipment creation and tracking.
- Returns, refunds and exchanges.
- **Exit criterion:** a complete purchase journey from browse to delivered order, with a compliant invoice, executed in test mode.

Stage 4 — Seller portal and verification

- Seller registration, KYC collection and document upload.
- GSTIN, PAN and bank verification integration.
- Seller approval workflow with structured decision reasons.
- GI certificate submission, verification queue and expiry monitoring.
- Listing creation, moderation queue and badge assignment.
- Inventory management and order fulfilment views.
- Earnings ledger and payout dashboard.
- **Exit criterion:** a seller can register, be verified, list a product, have it approved, receive an order, fulfil it and see the resulting earnings.

Stage 5 — Administration

- Admin panel across users, products, orders, sellers and payments.
- RBAC role assignment and permission management.
- GI verification officer tooling.
- Seller approval, suspension and offboarding.
- Settlement runs and payout approval.
- Reporting: sales, revenue, traffic, product, demand and GST, with PDF, Excel and CSV export.
- Audit log and content moderation tooling.
- **Exit criterion:** the platform can be operated entirely through the admin panel, with no database access required.

Stage 6 — Heritage content and engagement

- GI Tag module: cultural context, origin stories, certification explanation, verification display.
- Traditions module: artisan and tradition profiles with multimedia.
- Events calendar with management interface.
- Blog and editorial content management.
- Cross-linking from heritage content to related products.
- Reviews and ratings for products and sellers, with moderation.
- Wishlist, referrals, offers, coupons, up-sell and cross-sell.

- Recommendation engine.
- Notifications across email, SMS, push and in-app.
- **Exit criterion:** the full feature set of the Scope of Work is present and operable.

Stage 7 — Mobile applications

- iOS and Android applications against the same API.
- Native payment checkout with UPI intent handling.
- Push notification registration and handling.
- Deep linking for referrals and shared products.
- Store listing preparation and submission.
- **Exit criterion:** both applications submitted and approved.

Stage 8 — Hardening and assurance

- Performance optimisation against Core Web Vitals thresholds.
- Load testing on catalogue, search and checkout paths.
- Accessibility audit against WCAG 2.1 Level AA, automated and manual.
- Cross-browser verification on Chrome, Firefox, Safari and Edge, across desktop, tablet and mobile.
- Internal security review and dependency audit.
- **Independent VAPT by the CERT-In empanelled auditor, remediation, and re-test to clearance.**
- Backup and recovery rehearsal.
- **Exit criterion:** VAPT clearance certificate issued.

Stage 9 — Acceptance and go-live

- User acceptance testing by the Company's nominated testers, per surface.
- Production credential activation across all integrations.
- Controlled production verification — real payment, real shipment, real notification.
- Content and catalogue loading.
- Administrator and seller training, with documentation handover.
- Monitoring, alerting and on-call readiness.
- Go-live, with heightened monitoring.

10.2 Engineering practices applied throughout

PRACTICE	APPLICATION
Branch-based development	Every change is developed on its own branch and merged only through a reviewed pull request. The main branch is always deployable.
Mandatory code review	No change reaches the main branch without review by another engineer.
Automated quality gates	Type checking, linting, tests and security scanning run on every pull request. A failing gate blocks the merge; it is not overridden.

PRACTICE	APPLICATION
Definition of done	A feature is complete when it is implemented, tested, reviewed, documented, accessible, and demonstrated on staging — not when the code compiles.
Continuous deployment to staging	Every merge deploys automatically to staging, so the Company can review progress continuously rather than at milestones.
Controlled production release	Production deployment is deliberate and approved, with a tested rollback path.
Migration discipline	Every schema change is a versioned, reversible migration applied through the pipeline. No manual production data changes.
Dependency maintenance	Dependencies are monitored for vulnerabilities and updated on a defined cadence, with security patches expedited.
Documentation alongside code	API documentation is generated from the code. Runbooks and architecture notes live in the repository and are updated with the change that affects them.

10.3 Communication and visibility

- A continuously updated staging environment the Company can access at any time.
- Regular working demonstrations of completed functionality.
- A shared issue tracker giving full visibility of what is in progress, blocked or complete.
- A maintained register of decisions taken and matters awaiting Company input.
- Prompt escalation of any dependency at risk of blocking progress.

SECTION 11

Environments & Configuration

11.1 Environments

ENVIRONMENT	PURPOSE	CHARACTERISTICS
Local	Individual development	Runs on the developer's machine through Docker Compose. All third-party services stubbed or local. No live credentials.
Development	Shared integration	Deployed automatically from the main branch. Third-party services in sandbox mode. Synthetic data.
Staging	Company review, acceptance testing, VAPT	Production-equivalent configuration and infrastructure. Third-party services in sandbox or test mode. Anonymised data only.
Production	Live service	Live credentials. Restricted access. Full monitoring, alerting and backup. All changes deliberate and approved.

DATA SEPARATION

Production data is never copied into a lower environment in identifiable form. Where realistic data is needed for testing, it is anonymised first. This is both a data-protection obligation and a practical safeguard against a test process contacting real customers.

11.2 Configuration surface

All environment-specific values are supplied as configuration and validated at process start. If a required value is missing or malformed, the process fails immediately with a clear message rather than starting and failing later under load.

CONFIGURATION GROUP	CONTENTS
Application	Environment name, process role, port, public URLs, log level.
Database	Atlas connection string, database name, pool settings.
Cache and queue	Redis connection details, TLS settings, logical database allocation.
Authentication	Token signing secrets, token lifetimes, cookie policy.
Payments	Razorpay key identifier, secret, webhook signing secret.
Logistics	Per-carrier credentials, endpoints and pickup location identifiers.
Communications	Email provider credentials and sender identity; SMS key, sender identifier and template identifiers; push credentials.

CONFIGURATION GROUP	CONTENTS
Identity	Google and Facebook client identifiers and secrets, redirect URIs.
Storage	AWS credentials or role, region, bucket names, CDN domain, signing keys.
Verification	KYC provider credentials and endpoints.
Taxation	Company GSTIN, invoice series, HSN and rate mapping reference, e-invoicing credentials if applicable.
Observability	Sentry endpoint, release identifier, metrics endpoint.
Platform rules	Default commission, settlement cycle, return window, currency, timezone, supported locales.
Feature flags	Per-environment toggles allowing functionality to be enabled or disabled without deployment.

A complete reference appears in [Appendix A](#).

SECTION 12

Security, Compliance & Data Residency

The agreement imposes specific and non-negotiable security and compliance obligations. This section states how each is met, because several of them constrain technical choices made earlier in this document.

12.1 Data residency

INDIA-ONLY DATA RESIDENCY

All personal and payment data resides in India. This is the reason MongoDB Atlas is provisioned in the **Mumbai (ap-south-1)** region, all AWS resources are provisioned in the same region, and every third-party service is assessed for its data storage location before adoption.

This constraint is applied at provisioning rather than by policy alone: a cluster or bucket created in the wrong region cannot be relocated without migration. It is verified as part of infrastructure review, and the infrastructure-as-code definitions make the region explicit and auditable.

12.2 Encryption

OBLIGATION	IMPLEMENTATION
AES-256 at rest	Applied to the Atlas cluster, S3 buckets, ElastiCache, and all backups and snapshots. Managed keys are used, with key rotation enabled.
TLS 1.3 in transit	Enforced at the load balancer and at the edge. Earlier protocol versions are disabled, not merely deprioritised. Internal service-to-service traffic is also encrypted.
Credentials at rest	Passwords hashed with bcrypt and a per-password salt. Tokens signed and short-lived. Third-party credentials held in Secrets Manager, never in source or images.

12.3 Access logging

Access to personal data is logged and retained for **180 days**, in accordance with CERT-In directions. Each entry records who accessed what, when, from where, and by what action. Logs are written to immutable storage and are not modifiable by application code. This directly supports the audit trail the GI verification workflow requires.

12.4 Independent security assessment

A vulnerability assessment and penetration test is conducted by a **CERT-In empanelled auditor independent of the Development Team**, before go-live and before each major release. Findings are remediated and re-tested to clearance. This is a launch gate, as noted in Section 10, Stage 8.

12.5 Statutory obligations

OBLIGATION	PLATFORM SUPPORT
Consumer Protection (E-Commerce) Rules, 2020	Mandatory seller disclosures — legal identity, address, contact and grievance details; country of origin on every listing; per-seller return, refund and exchange policy; and a published grievance officer mechanism with defined acknowledgement and resolution handling.
Information Technology Act, Section 79	Intermediary protections require content moderation and takedown capability. The platform provides moderation tooling, takedown workflow, and a complete audit trail of moderation actions.
GST law	Compliant invoicing with separate vendor-GST and consumer-GST categorisation; correct tax computation; credit notes against returns; and automated category-wise reporting. Dependent on the Company inputs in Section 8.5.
Digital Personal Data Protection Act	Consent capture, purpose limitation, data subject access and deletion handling, breach notification capability, and retention policy enforcement.
Geographical Indications of Goods Act	The verification workflow exists to ensure GI claims correspond to genuine registrations, and to maintain evidence of each verification decision.

12.6 Accessibility

WCAG 2.1 Level AA across web and mobile. This is addressed through construction rather than remediation: accessible component primitives, semantic markup, verified colour contrast in the design tokens, full keyboard operability, visible focus indication, meaningful alternative text, correct form labelling and error association, and screen-reader announcement of dynamic changes. Automated checks run in the test pipeline; manual keyboard and screen-reader review is performed in Stage 8.

12.7 Browser and device support

CATEGORY	SUPPORT
Desktop browsers	Chrome, Firefox, Safari and Edge — current and immediately preceding major versions.
Mobile browsers	Chrome on Android; Safari on iOS.
Devices	Desktop, tablet and mobile, with responsive layouts verified at each breakpoint.
Mobile applications	iOS and Android, on currently supported operating system versions.

12.8 Application security measures

- Input validation on every request
- Injection prevention on all queries
- Output encoding against cross-site scripting
- Content Security Policy enforcement
- Cross-site request forgery protection
- Rate limiting on all public endpoints
- Automated abuse protection on sensitive endpoints

- Least-privilege database users
- Short-lived tokens with immediate revocation
- Two-factor authentication for administrators
- Signed, time-limited URLs for private documents
- Webhook signature verification on raw payloads
- Idempotency on all state-changing operations
- Dependency vulnerability scanning in the pipeline
- Secret scanning on every commit
- Audit logging of all privileged actions

12.9 Backup and recovery

- Continuous database backup with point-in-time recovery through Atlas.
- Object storage versioning, so an overwritten or deleted file is recoverable.
- Infrastructure defined as code, so an environment can be rebuilt from the repository.
- Recovery procedures documented and rehearsed before go-live, not assumed.

SECTION 13

Assumptions & Dependencies

13.1 Assumptions

The technical approach in this document rests on the following. If any proves incorrect, the affected section should be revisited during discovery.

1. The Company holds, or will hold before the relevant integration, a registered Indian legal entity with GST registration and a corporate bank account.
2. All third-party accounts requiring a legal entity will be opened in the Company's name, with delegated access granted to the Development Team.
3. The Company's tax advisors will provide the determination and mappings listed in Section 8.5 before invoicing and settlement are built.
4. Legal and policy documents in Section 8.4 will be provided by the Company's legal advisors.
5. Primary transaction currency is Indian Rupees; primary timezone is India Standard Time.
6. Interface languages at launch are English and Hindi, with Hindi translations supplied or approved by the Company.
7. The platform operates as a marketplace facilitator; sellers are independent parties and the platform does not hold inventory.
8. Payments are collected through Razorpay and settled to the Company, which then settles to sellers under rules the Company defines.
9. The CERT-In empanelled auditor will be appointed by the Company and is independent of the Development Team.
10. Heritage, editorial and events content will be supplied by the Company; the platform provides the management tooling for it.
11. Memory games and child development models are out of scope, per Section 9.5.
12. Quick-commerce channel integration is subject to feasibility review and is not committed.

13.2 Dependencies outside the Development Team's control

Progress on the following depends on external parties. Each is identified here so it can be initiated early and tracked, rather than discovered as a blocker:

- TRAI DLT entity, sender and template approval.
- Razorpay business KYC and account activation.
- Carrier commercial agreements and API certification.
- Email provider sandbox removal.
- Google OAuth consent screen verification.
- Meta business verification and App Review.
- Apple Developer enrolment, including D-U-N-S issuance.
- App Store and Play Store review outcomes.
- The Company's taxation determination.

- Company-supplied content, translations and brand assets.
- Company decisions on the matters in Section 9.
- CERT-In auditor availability and clearance.

THE SINGLE MOST USEFUL ACTION

Of everything in this document, initiating **TRAI DLT registration**, **Razorpay account opening** and **Apple Developer enrolment** at the earliest opportunity removes the three dependencies most likely to constrain progress later. None requires the platform to exist, all require only Company documents, and each takes as long as it takes regardless of engineering readiness.

APPENDIX A

Configuration Reference

The complete configuration surface. Values marked **Company** must be supplied by the Company; those marked **Team** are generated or configured by the Development Team.

CONFIGURATION KEY	SOURCE	DESCRIPTION
APPLICATION		
NODE_ENV	Team	Environment identifier.
PROCESS_ROLE	Team	Selects api, worker or scheduler behaviour.
PORT	Team	Listening port.
APP_URL / API_URL	Company	Public addresses, derived from the Company domain.
LOG_LEVEL	Team	Logging verbosity.
DATABASE AND CACHE		
MONGODB_URI	Team	Atlas connection string, per environment.
MONGODB_DB_NAME	Team	Database name.
REDIS_URL	Team	Redis connection, with TLS in production.
AUTHENTICATION		
JWT_ACCESS_SECRET	Team	Access token signing secret.
JWT_REFRESH_SECRET	Team	Refresh token signing secret.
JWT_ACCESS_EXPIRES / JWT_REFRESH_EXPIRES	Team	Token lifetimes.
GOOGLE_CLIENT_ID / GOOGLE_CLIENT_SECRET	Company	Google sign-in credentials.
FACEBOOK_APP_ID / FACEBOOK_APP_SECRET	Company	Facebook sign-in credentials.
PAYMENTS		
RAZORPAY_KEY_ID	Company	Gateway key identifier.
RAZORPAY_KEY_SECRET	Company	Gateway secret.
RAZORPAY_WEBHOOK_SECRET	Company	Webhook signature verification secret.

CONFIGURATION KEY	SOURCE	DESCRIPTION
LOGISTICS		
DELHIVERY_API_TOKEN / DELHIVERY_CLIENT_NAME	Company	Carrier credentials.
BLUEDART_LICENCE_KEY / BLUEDART_LOGIN_ID	Company	Carrier credentials.
DTDC_API_KEY / DTDC_CUSTOMER_CODE	Company	Carrier credentials.
INDIAPOST_CUSTOMER_ID / INDIAPOST_API_KEY	Company	Carrier credentials.
PICKUP_LOCATIONS	Company	Registered pickup addresses per carrier.
COMMUNICATIONS		
AWS_SES_REGION / MAIL_FROM	Company	Email region and verified sender identity.
MSG91_AUTH_KEY	Company	SMS provider key.
MSG91_SENDER_ID	Company	DLT-registered sender identifier.
MSG91_TEMPLATE_IDS	Company	DLT-approved template identifiers, one per message type.
FIREBASE_SERVICE_ACCOUNT	Company	Push notification service credentials.
VAPID_PUBLIC_KEY / VAPID_PRIVATE_KEY	Team	Web push keys.
STORAGE AND DELIVERY		
AWS_REGION	Team	Fixed to ap-south-1 for data residency.
AWS_S3_BUCKET_PUBLIC / AWS_S3_BUCKET_PRIVATE	Team	Storage buckets.
CLOUDFRONT_DOMAIN / CLOUDFRONT_KEY_PAIR_ID	Team	Content delivery and signed URL configuration.
VERIFICATION AND TAXATION		
KYC_PROVIDER_KEY / KYC_PROVIDER_URL	Company	GSTIN, PAN and bank verification.
COMPANY_GSTIN	Company	Company GST identifier for invoicing.
INVOICE_SERIES_VENDOR / INVOICE_SERIES_CONSUMER	Company	Invoice numbering series.

CONFIGURATION KEY	SOURCE	DESCRIPTION
EINVOICE_PROVIDER_CREDENTIALS	Company	ASP or GSP credentials, if e-invoicing applies.
THIRD-PARTY SERVICES		
GOOGLE_MAPS_API_KEY	Company	Address and mapping services.
RECAPTCHA_SITE_KEY / RECAPTCHA_SECRET_KEY	Company	Abuse protection.
SENTRY_DSN	Company	Error tracking endpoint.
GA4_MEASUREMENT_ID	Company	Analytics property.
PLATFORM RULES		
DEFAULT_COMMISSION_PERCENT	Company	Default marketplace commission.
SETTLEMENT_CYCLE	Company	Payout frequency.
RETURN_WINDOW_DAYS	Company	Return eligibility period.
DEFAULT_CURRENCY / DEFAULT_TIMEZONE	Company	INR and Asia/Kolkata.
SUPPORTED_LOCALES	Company	English and Hindi.
FEATURE_FLAGS	Team	Per-environment functionality toggles.

APPENDIX B

Glossary

TERM	DEFINITION
API	Application Programming Interface. The defined set of operations one system exposes for another to call.
ASP / GSP	Application Service Provider / GST Suvidha Provider. Authorised intermediaries for submitting e-invoices to the government portal.
CERT-In	Indian Computer Emergency Response Team, the national cybersecurity agency. Empanelled auditors permitted to conduct statutory security assessments.
DLT	Distributed Ledger Technology. The TRAI-mandated registration platform on which SMS sender identities and message templates must be approved before delivery is permitted.
D-U-N-S number	A unique business identifier required for organisation enrolment in the Apple and Google developer programmes.
GI	Geographical Indication. A legal mark identifying goods as originating from a specific place, whose qualities or reputation derive from that origin.
GSTIN	Goods and Services Tax Identification Number, issued on GST registration.
HSN code	Harmonised System of Nomenclature. The classification code determining the GST rate for a product.
Idempotency	The property that repeating an operation produces the same result as performing it once. Prevents duplicate charges or orders on retry.
KYC	Know Your Customer. Identity and business verification required before financial services are provided.
MERN	MongoDB, Express.js, React and Node.js — the technology stack used for this platform.
Penny drop	Bank account verification performed by depositing a nominal amount and reading back the registered account holder name.
RBAC	Role-Based Access Control. Permissions granted by role rather than to individuals.
SRS	Software Requirements Specification. The agreed definition of what will be built.
SSR	Server-Side Rendering. Generating page content on the server so it is present in the initial response and visible to search engines.
TCS	Tax Collected at Source. Under Section 52 of the CGST Act, marketplace operators may be required to collect tax on supplies made through the platform.
TDS	Tax Deducted at Source, applicable to certain payments including seller settlements.

TERM	DEFINITION
TRAI	Telecom Regulatory Authority of India.
VAPT	Vulnerability Assessment and Penetration Testing. Independent security assessment.
WCAG 2.1 AA	Web Content Accessibility Guidelines, Level AA — the accessibility standard required by the agreement.
Webhook	A server-to-server callback by which a third-party service notifies the platform of an event, such as a completed payment.

End of document.

Prepared as a companion to the Tag Traditions Software Development Agreement, Scope of Work §1.1–§1.4, with compliance obligations drawn from §8 and §13.2. This document addresses technology, packages, tooling, integrations, onboarding, requirements and approach only. Timelines, schedules, effort and commercial terms are addressed separately under the agreement.